
Plantilla de Matriz de Riesgos

Actividad A03 — Administración de Riesgos
Análisis y Gestión de Riesgos en Sistemas de Información

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
Docente: Ing. Rodrigo Atilio Elgueta
Ciclo Académico Vigente

Índice

1. Datos Generales	2
2. Objetivo y Alcance del Análisis	2
3. Inventario y Clasificación de Activos	3
4. Identificación de Amenazas y Vulnerabilidades	3
5. Escalas de Valoración	4
5.1. Escala de Probabilidad	4
5.2. Escala de Impacto	4
6. Matriz de Calor (Probabilidad × Impacto)	4
6.1. Niveles de Riesgo	5
7. Evaluación de Riesgos	5
8. Tratamiento de Riesgos y Riesgo Residual	5
9. Resumen de Resultados	6
10. Conclusiones y Recomendaciones	6
11. Declaración de Buenas Prácticas	6
12. Referencias Bibliográficas	6

Cómo usar esta plantilla

Esta plantilla es el instrumento formal para desarrollar la **Actividad A03 — Administración de Riesgos**. Completá cada sección con la información de la empresa real, ficticia o caso del Trabajo Integrador que hayas elegido.

Recomendaciones:

- Completá los campos de la Sección 1 antes de iniciar el análisis.
- Asigná un **código (ID)** único a cada activo, amenaza y riesgo para poder referenciarlos en las tablas.
- Usá las escalas de las Secciones 5 para valorar probabilidad e impacto de forma consistente.
- Para cada riesgo identificado, calculá el **valor de riesgo** ($Probabilidad \times Impacto$) y clasificá el nivel según la Sección 6.1.
- Proponé salvaguardas y calculá el **riesgo residual** (Sección 8).
- Subí el informe completado a la carpeta del Trabajo Integrador en Google Drive, otorgando permisos de comentario a era.profe@gmail.com.

1. Datos Generales

Nombre de la empresa /
organización

Rubro / Industria

Tamaño (empleados / facturación)

Alumno(s) / Grupo

Legajo(s)

Fecha de elaboración

Responsable del análisis

2. Objetivo y Alcance del Análisis

Alcance: (sistemas, procesos, sedes o áreas incluidas en el análisis)

3. Inventario y Clasificación de Activos

Asigná un código único a cada activo (ej.: A01, A02...). La clasificación de la información puede ser: *Pública, Interna, Confidencial, Restringida*.

ID	Descripción del Activo	Tipo	Responsable	Clasificación	Criticidad
----	------------------------	------	-------------	---------------	------------

Tipos de activo: Información / Software / Hardware / Red / Humano / Imagen. Criticidad: Baja / Media / Alta.

4. Identificación de Amenazas y Vulnerabilidades

Asigná un código único a cada amenaza (ej.: T01, T02...). El tipo puede ser: *Natural, Accidental, Intencional*.

ID	Activo (ID)	Descripción de la Amenaza	Tipo	Vulnerabilidad Asociada
----	-------------	---------------------------	------	-------------------------

5. Escalas de Valoración

5.1. Escala de Probabilidad

Valor	Nivel	Descripción
1	Raro	El evento solo ocurriría en circunstancias excepcionales.
2	Improbable	Podría ocurrir, pero no se espera que suceda.
3	Posible	Existe una posibilidad real de que ocurra.
4	Probable	Es muy probable que ocurra en algún momento.
5	Casi seguro	Se espera que ocurra frecuentemente / ha ocurrido recientemente.

5.2. Escala de Impacto

Valor	Nivel	Descripción
1	Insignificante	Impacto mínimo, sin consecuencias operativas ni económicas relevantes.
2	Menor	Alteración leve de la operación, costo bajo.
3	Moderado	Impacto operativo y económico apreciable, recuperable.
4	Mayor	Impacto significativo, pérdida de operación o datos, costo alto.
5	Catastrófico	Paralización total, pérdida crítica de datos, daño reputacional o legal severo.

6. Matriz de Calor (Probabilidad × Impacto)

La matriz 5×5 relaciona la **probabilidad** (eje vertical) con el **impacto** (eje horizontal). Cada celda muestra el valor de riesgo resultante ($P \times I$) y su color indica el nivel.

		IMPACTO →				
		1	2	3	4	5
↑ PROBABILIDAD	5	5	10	15	20	25
	4	4	8	12	16	20
	3	3	6	9	12	15
	2	2	4	6	8	10
	1	1	2	3	4	5

6.1. Niveles de Riesgo

Nivel	Rango (P×I)	Color	Acción requerida
Bajo	1 – 4	Verde	Monitorear. Puede aceptarse.
Medio	5 – 9	Amarillo	Plan de acción a mediano plazo.
Alto	10 – 15	Naranja	Tratamiento prioritario a corto plazo.
Crítico	16 – 25	Rojo	Acción inmediata. Escalar a dirección.

7. Evaluación de Riesgos

Asigná un código único a cada riesgo (ej.: R01, R02...). Calculá el valor como *Probabilidad* × *Impacto* y clasificá el nivel según la tabla anterior.

ID	Activo	Amenaza	Prob.	Impacto	Valor	Nivel	Justificación breve
----	--------	---------	-------	---------	-------	-------	---------------------

8. Tratamiento de Riesgos y Riesgo Residual

Para cada riesgo, definí la estrategia de tratamiento:

- **Mitigar:** implementar salvaguardas para reducir probabilidad o impacto.
- **Transferir:** pasar el riesgo a un tercero (seguros, outsourcing).
- **Aceptar:** asumir el riesgo conscientemente.
- **Evitar:** discontinuar la actividad que lo genera.

Riesgo	Estrategia	Salvaguardas propuestas	Tipo salv.	Prob. resid.	Imp. resid.	Val. resid.	Nivel resid.
--------	------------	-------------------------	------------	--------------	-------------	-------------	--------------

Tipo de salvaguarda: Técnica / Física / Administrativa. El nivel residual se clasifica con la misma tabla de la Sección 6.1.

9. Resumen de Resultados

Distribución de los riesgos identificados por nivel (completar con la cantidad de riesgos en cada categoría):

Nivel	Cantidad de riesgos	% del total
Crítico		
Alto		
Medio		
Bajo		
Total		100 %

10. Conclusiones y Recomendaciones

11. Declaración de Buenas Prácticas

Compromiso profesional

Como estudiante de Seguridad Aplicada a Sistemas de Información, declaro que el presente análisis de riesgos fue elaborado aplicando las buenas prácticas de la disciplina, con criterio ético, fundamentos técnicos y respetando el marco normativo vigente.

Firma del alumno/a

Fecha

12. Referencias Bibliográficas

- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial — eLibro.
- ISO/IEC (2005). *Information security management 27001*.

- ISO/IEC (2018). *ISO/IEC 27005: Information security risk management*.
- NIST (2012). *Guide for Conducting Risk Assessments (SP 800-30 Rev. 1)*.
- OWASP Risk Rating Methodology: https://owasp.org/www-community/OWASP_Risk_Rating_Methodology